

MAPEO GQM + PREGUNTAS + NORMATIVA

Correspondencia entre Objetivos, Preguntas GQM, Métricas e Instrumentos Regulatorios

Versión 1.0 — Abril 2026

"Cada métrica que no sepa justificar qué objetivo persigue, qué pregunta responde y qué artículo de qué norma ayuda a cumplir, sabe demasiado poco de sí misma para seguir viva."

1. ESTRUCTURA DEL MAPEO

Esta tabla enlaza:

- **Objetivos GQM (Goals):** Estratégicos (GO.x) y específicos por dominio (G-DRx, G-CVx, G-GOVx, G-FINx, G-EMx).
- **Preguntas GQM (Questions):** Preguntas operativas que concretan el objetivo.
- **Métricas (Metrics):** Indicadores concretos.
- **Normativa asociada:** NIS2, ENS, DORA, ISO 27001:2022, NIST CSF 2.0.
- **Preguntas de la Encuesta MSS:** Ítems que recogen la existencia/uso de esa métrica.

2. TABLA PRINCIPAL DE MAPEO

Goal (GQM)	Question (GQM)	Metric (M)	Pregunta(s) Encuesta	NIS2 / Ley Gobernanza	ENS (RD 311/20 22)	DORA	ISO 27001: 2022	NIST CSF 2.0	Comentario clave
G-DR1: Reducir el tiempo de detección de incidentes críticos hasta niveles compatibles con la ventana NIS2 (24h) y con la velocidad de los atacantes	Q-DR1.1: ¿En cuánto tiempo se detectan los incidentes críticos desde el inicio de la actividad maliciosa?	MTTD medio (min/h) incidentes ALTA/CRÍTICA	P3.1, P3.2	Art. 21.2 b) (gestión de incidentes); Art. 23 (notificación en 24h)	op.exp. 3 (detección y gestión de incidentes)	Art. 11.1 (detección precoz de incidentes TIC)	A.8.16 (monitorización de actividades); A.5.26 (gestión de incidentes)	DE.CM-01, DE.CM-08	Sin MTTD medido y aceptable es prácticamente imposible cumplir NIS2 Art. 23 en la práctica
G-DR1	Q-DR1.2: ¿Cuál es la tendencia del MTTD en los últimos 12 meses?	Tendencia MTTD ($\Delta\%$ YoY)	P3.2	Art. 21.1 (mejora continua)	org.4 (revisión de eficacia de medidas)	Art. 6.5 (marco de riesgos dinámico)	Cl. 9.3 (revisión por la dirección)	ID.IM-01	La tendencia es tan importante como el valor absoluto para juzgar madurez

G-DR2: Limitar el impacto de incidentes reduciendo el tiempo de contención	Q- DR2.1: ¿Cuánto tiempo transcurre entre la detección y la contención efectiva?	MTTC medio (min/h)	P3.3, P3.4 (indirectamente)	Art. 21.2 b) NIS2	op.exp. 3	Art. 11.2 DORA	A.5.26	RS.MA- 01	Métrica crítica para controlar el "blast radius" de ransomware
G-DR2	Q- DR2.2: ¿Qué % de incidentes se contiene dentro del SLA?	% incidentes contenidos < SLA	P2.5, P2.6 (SLA); P3.4	Art. 30.2 g) DORA (SLAs con indicadores)	—	Art. 30 (cláusulas contractuales)	A.5.20	GV.SC- 10	Conecta calidad MSS con obligaciones de terceros en DORA
G-DR3: Minimizar el tiempo de recuperación segura tras incidentes severos	Q- DR3.1: ¿Cuál es el MTTR medio de incidentes críticos?	MTTR medio (h/días)	P3.3, P3.4; P5.3 (RTO)	Art. 21.2 c) NIS2 (continuidad y recuperación)	op.cont. 1 (continuidad de la actividad)	Art. 11.3 DORA	A.5.29, A.5.30 (continuidad)	RC.RP- 01, RC.RP- 03	El MTTR debe estar alineado con RTO/R PO para que el BCP sea realista
G-DR3	Q- DR3.2: ¿Qué % de incidentes cumple el RTO definido?	% incidentes dentro de RTO	P5.3	Art. 21.2 c) NIS2	op.cont. 1	Art. 11.3 DORA	A.5.30	RC.RP- 03	Métrica puente entre seguridad y continuidad de negocio

G-DR4: Reducir la fatiga de analistas y el riesgo de incidentes pasados por alto	Q- DR4.1: ¿Qué % de alertas son falsos positivos?	False Positive Rate (FPR)	P3.5	Art. 21.2 a) NIS2 (eficacia de medidas)	op.mon. 1	Art. 11.6 DORA	A.8.16	DE.AE- 04	Alta FPR afecta indirectamente al cumplimiento (incidentes no investigados)
G-CV1: Minimizar superficie de ataque no monitorizada	Q-CV1.1: ¿Qué % de activos críticos están monitoreados?	ACR global y por crítica	P3.6, P6.5	Art. 21.2 a) NIS2	op.pl.1 (inventario), op.mon. 1	Art. 8.1 DORA (registro de activos TIC)	A.5.9 (inventario)	ID.AM- 01, ID.AM- 02	ACR <80% implica altos niveles de "shadow IT" y brechas estructurales
G-CV2: Reducir exposición a vulnerabilidades críticas explotables	Q- CV2.1: ¿Cuál es el tiempo medio de remediación de CVEs críticas?	Tiempo medio de remediación (días) CVSS≥9	P3.7, P3.8	Art. 21.2 b) NIS2 (gestión de vulnerabilidades)	op.exp. 2	Art. 9.4 DORA	A.8.8 (gestión de vulnerabilidades)	ID.RA- 05	Métrica directamente requerida por NIS2: gestión de vulnerabilidades
G-CV2	Q- CV2.2: ¿Qué % de CVEs críticas permanece abierto >30 días?	% CVEs críticas >30d	P3.8	Art. 21.2 b) NIS2	op.exp. 2	Art. 9.4 DORA	A.8.8	PR.PS- 02	Conecta gestión de vulnerabilidades con listas KEV de CISA

G-GOV1: Garantizar autenticación fuerte en accesos relevantes	Q-GOV1.1: ¿Qué % de cuentas tiene MFA obligatorio?	% cuentas con MFA	P6.3	Art. 21.2 j) NIS2 (MFA explícito); Art. 21.2 a)	op.acc.5	Art. 9.4 b) DORA	A.8.5 (autenticación segura)	PR.AA-03	NIS2 menciona explícitamente la MFA como control obligatorio
G-GOV1	Q-GOV1.2: ¿Qué flujos críticos carecen de MFA?	Nº flujos sin MFA	P6.3	Art. 21.2 j) NIS2	op.acc.1-5	Art. 9.4 DORA	A.8.2-A.8.6	PR.AA-01-05	Ayuda a priorizar proyectos de implantación MFA
G-GOV2: Asegurar cumplimiento ENS en sistemas AAPP/proveedores	Q-GOV2.1: ¿Cuál es el estado de certificación/adecuación ENS?	Compliance score ENS	P4.1	ENS RD 311/2022 (todo el articulado)	mp.org, op.* según categoría	—	ISO 27001 equivalente parcial	Todos	ENS condiciona contratación pública y elegibilidad para proyectos
G-GOV3: Prepararse para NIS2 / Ley Gobernanza	Q-GOV3.1: ¿Se ha realizado análisis de brechas NIS2?	Estado de preparación NIS2 (categorico)	P4.2	Directiva NIS2 completa; Anteproyecto español	—	—	—	GV.PO-02	Indicador de madurez regulatoria; sin análisis hay ceguera normativa

G-COMP1: Cumplir plazos de notificación NIS2/DORA	Q-COMP1.1: ¿Existen procesos que aseguren notificación 24h/72h/1mes?	Procedimiento documentado (S/N) y % de incidentes notificados en plazo	P4.3	Art. 23 NIS2 (24h/72h/1mes); Art. 19 DORA (plazos notificación financiera)	op.exp.7 (notificación)	Art. 19 DORA	A.5.24 (plan de respuesta a incidentes)	RS.CO-02	Los plazos de notificación son exigibles; fallo repetido expone a sanción
G-RISK1: Gestionar el riesgo de proveedores y cadena de suministro	Q-RISK1.1: ¿Cuántos proveedores críticos cuentan con evaluación de seguridad formal?	% proveedores críticos evaluados (TPRM coverage)	P4.7, P2.3	Art. 21.1 d) y 21.3 NIS2 (supply chain)	op.ext.1	Art. 28-30 DORA	A.5.19-A.5.22	GV.SC-01-10	La falta de TPRM estructurado es una de las brechas más graves bajo NIS2/DORA
G-FIN1: Justificar inversión en MSS por reducción de riesgo	Q-FIN1.1: ¿Cuál es la ALE sin controles MSS?	ALE_sin_controles	P9.1, P9.4; Hoja 4 Excel	Art. 21.1 a) NIS2 (análisis de riesgo)	mp.inf.1	Art. 6.1 DORA (marco de riesgo)	Cl. 6.1.2	ID.RA-01-09	Marco actuarial recomendado por CAS/ISO 27005
G-FIN1	Q-FIN1.2: ¿Cuál es la ALE con controles MSS?	ALE_con_controles	P9.1	Art. 21.1 a) NIS2	mp.inf.1	Art. 6.5 DORA	Cl. 6.1.3	ID.RA-09	Permite cuantificar pérdidas evitadas

G-FIN1	Q-FIN1.3: ¿Cuál es el ROSI de MSS?	ROSI (%) y Payback	P9.4; Hoja 4 Excel	Art. 21.1 (medidas proporcionadas)	—	Art. 17 DORA (recursos adecuados)	Cl. 6.1.3	GV.OV-05	Traductor directo al lenguaje del CFO/Consejo
G-RES1: Garantizar continuidad de negocio ante ciberincidentes	Q-RES1.1: ¿Existe un BCP con escenarios ciber probados?	Existencia y estado BCP	P5.1, P5.2	Art. 21.2 c) NIS2	op.cont. 1-3	Art. 11 DORA	A.5.29, A.5.30	RC.RP-01	BCP sin escenarios ciber = brecha típica en auditorías
G-CTI1: Integrar inteligencia de amenazas en detección	Q-CTI1.1: ¿Se consume e integra CTI de forma sistemática?	Nivel de integración CTI (categorico)	P8.1, P8.2	Art. 21.2 f) NIS2	op.mon. 5	Art. 11.5 DORA	A.5.7 (inteligencia de amenazas)	DE.AE-02, ID.RA-02	NIS2 menciona cadena de suministro y amenazas; CTI es puente lógico
G-EM1: Preparar transición a criptografía postcuántica	Q-EM1.1: ¿Qué % de sistemas son criptográficamente ágiles?	Crypto-Agility Score	P10.1, P10.2	Art. 21 (gestión de riesgos emergentes)	mp.com .2	Art. 9 DORA	A.8.24 (uso de criptografía)	PR.DS-01	Pendiente de explicitación en futuras guías ENISA/NIS, pero ya presente en tendencias

3. USO DEL MAPEO EN DISEÑO DE SLAs Y AUDITORÍAS

1. Diseño de SLAs MSS:
2. Incorporar explícitamente métricas GQM alineadas a artículos concretos de NIS2/DORA (ej. MTDD/MTTR → Art. 23 NIS2, Art. 11 DORA).
3. Referenciar en el SLA el artículo normativo que la métrica contribuye a satisfacer ("esta métrica apoya el cumplimiento de...").
4. Preparación de auditorías ENS/NIS2:
5. Utilizar la tabla para demostrar trazabilidad: cada hallazgo mejora una métrica que a su vez responde a un objetivo regulatorio.
6. Justificación ante el Consejo:
7. Traducir cualquier petición de inversión o cambio en contrato MSS a la forma:
Objetivo regulatorio → Objetivo GQM → Pregunta → Métrica → Brecha → Acción → Coste → ROSI.

Referenciar en el SLA el artículo normativo que la métrica contribuye a satisfacer ("esta métrica apoya el cumplimiento de...").

Preparación de auditorías ENS/NIS2:

Utilizar la tabla para demostrar trazabilidad: cada hallazgo mejora una métrica que a su vez responde a un objetivo regulatorio.

Justificación ante el Consejo:

- Objetivo regulatorio → Objetivo GQM → Pregunta → Métrica → Brecha → Acción → Coste → ROSI.

Mapeo GQM + Preguntas + Normativa — Versión 1.0 · Abril 2026

Basado en: Directiva NIS2, ENS RD 311/2022, DORA, ISO/IEC 27001:2022, NIST CSF 2.0, ENISA MSS Market Analysis 2025, ECSMAF V3.0.